



Network Security

**Examine Software Flaws and How They have been Exploited in
Real World Systems**

Introduction

Software flaws and finding out how they have been exploited in real world systems is the main purpose of this lab. The MITRE Common Weakness Enumeration (CWE) Top 25 identifies the most dangerous software weaknesses that attackers consistently exploit across the industries. In this lab, I have selected CWE-352 - Cross-Site Request Forgery and CWE-863 - Incorrect Authorization to examine how weaknesses in request validation and authorization enforcement can lead to serious security breaches.

CWE-352 occurs when the web application does not properly verify that a request was intentionally provided by the user. CWE-863 occurs when a product does not correctly perform the check before granting access. We can use MITRE ATT&CK framework for mapping them to real attacker behaviors.

Part - 1

1. Used the following URL which provides information on the latest top 25 Common Weakness Enumeration (CWE): https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html to select two CWEs.

The screenshot shows the MITRE CWE Top 25 Most Dangerous Software Weaknesses page for 2025. The page header includes the MITRE logo, the title "Common Weakness Enumeration", and a subtitle "A community-developed list of SW & HW weaknesses that can become vulnerabilities". The page is divided into sections for "Top 25 Home", "Share via", "View in table format", "Key Insights", and "Methodology". The top 25 weaknesses are listed, with the first three being:

Rank	Weakness	CVEs in KEV	Rank Last Year	Change
1	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	7	1	
2	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	4	3 (up 1)	▲
3	Cross-Site Request Forgery (CSRF)	0	4 (up 1)	▲

2. I selected CWE-352 and CWE-863 to perform my lab work.



Cross-Site Request Forgery (CSRF)

[CWE-352](#) | CVEs in KEV: 0 | Rank Last Year: 4 (up 1) ▲



Incorrect Authorization

[CWE-863](#) | CVEs in KEV: 4 | Rank Last Year: 18 (up 1) ▲

3. CWE-352 Cross-Site Request Forgery (CSRF)

CWE-352 occurs when the web application does not or cannot properly verify that a request was intentionally provided by the user. This request may be coming from an unauthorized user by abusing the logged user's existing session and credentials.

Common consequences if exploited include gain privileges or assume identity, bypass protection mechanism, read or modify application data, DoS, Crash, Exit, or Restart the system. All together it will affect confidentiality, integrity, and availability of resources.

- An attacker can trick a victim's browser into sending unintended requests to a web server using mechanisms such as malicious URL, image load, XMLHttpRequest.
- These forged requests would be treated as authentic requests because they use the victim's active authentication session.
- If the victim is an administrator or privileged user, the consequences may include obtaining complete control over the web application - deleting or stealing data, uninstalling the product, or using it to launch other attacks against all the product's users.

Potential mitigation if exploited includes architecture and design changes, and implementations to the system.

- Use a vetted library or framework which provide built-in CSRF protection mechanisms to reduce implementation errors.
- Ensure that the application is free of cross-site scripting issues (CWE-79), because attacker-controlled script can bypass most CSRF defenses.
- Generate a unique nonce (token) for each form submission and validate it on the server side.
- Identify and send a separate confirmation request to ensure that the user intended to perform that operation.
- Use the "double-submitted cookie" method, which require matching CSRF tokens in both cookies and form data.
- Avoid using the HTTP GET method for requests that change application state.
- Check the HTTP Referer header to see if the request originated from a trusted page.

4. CWE-863 Incorrect Authorization

CWE-863 occurs when a product does not correctly perform the check before granting access. Normally, the product should perform an authorization check when an actor attempts to access a resource or perform an action.

Common consequences if exploited include reading application data, modifying application data, gaining privileges or assume identity, execute unauthorized code or commands, and DoS. All together it will affect confidentiality, integrity, and availability of resources.

- An attacker could bypass access controls to read sensitive data by reading it directly from data store or accessing insufficiently protected, privileged functionality to read the data will violate the confidentiality of data.
- An attacker could bypass access controls to modify sensitive data by writing the data directly to a data store or accessing insufficiently protected, privileged functionality to write the data will violate the integrity of data.
- An attacker could bypass access controls to gain privileges by modifying or reading critical data directly, or by accessing privileged functionality will violate the access controls.
- An attacker could use elevated privileges to execute unauthorized commands, or code will violate confidentiality, integrity, and availability of data.
- An attacker could bypass access controls to resources on the system and excessively consume those resources, leading to a denial of service (DoS) will affect the availability of data.

Potential mitigation if exploited includes architecture and design changes, and system configuration or installations to the system.

- Divide the product into anonymous, normal, privileged, and administrative areas to clearly separate access levels and reduce the attack surface.
- Implement role-based access control (RBAC) to ensure users can only access data and functionality assigned to their role.
- Ensure that access control checks are performed related to the business logic.
- Use vetted library or framework that provide built-in authorization controls and reduce implementation errors.
- Access control validates from server side for web applications to prevent users from bypassing controls by directly accessing restricted pages or functions.
- Apply Access Control Lists (ACLs) at the operating system and server level to restrict unauthorized access to resources.

Part - 2

1. Used the following URL to find information on the CWE-352 and CWE-863 Common Weakness Enumerations (CWEs) using MITRE ATT&CK:

<https://attack.mitre.org/techniques/enterprise/>

The screenshot shows the MITRE ATT&CK website. The header is red with the MITRE logo and a hamburger menu. Below the header, a banner states "ATT&CK v18 has been released! Check out the [blog post](#) or [changelog](#) for more information." The main content area is titled "Enterprise Techniques" and includes a breadcrumb trail: "Home > Techniques > Enterprise". A paragraph explains that techniques represent 'how' an adversary achieves a tactical goal. To the right, it says "Techniques: 216" and "Sub-techniques: 475". A table lists techniques, with the first row showing ID "T1548", Name "Abuse Elevation Control Mechanism", and Description "Adversaries may circumvent mechanisms designed to control elevate privileges to gain higher-level permissions. Most modern systems".

ID	Name	Description
T1548	Abuse Elevation Control Mechanism	Adversaries may circumvent mechanisms designed to control elevate privileges to gain higher-level permissions. Most modern systems

2. I selected User Execution: Malicious Link from MITRE ATT&CK using URL <https://attack.mitre.org/techniques/T1204/001/> which support CWE-352.

The screenshot shows the MITRE ATT&CK website for the "User Execution: Malicious Link" technique. The header is red with the MITRE logo and a hamburger menu. Below the header, a banner states "ATT&CK v18 has been released! Check out the [blog post](#) or [changelog](#) for more information." The main content area is titled "User Execution: Malicious Link" and includes a breadcrumb trail: "Home > Techniques > Enterprise > User Execution > Malicious Link". A dropdown menu shows "Other sub-techniques of User Execution (5)". A paragraph explains that an adversary may rely upon a user clicking a malicious link in order to gain execution. To the right, a box contains metadata: ID: T1204.001, Sub-technique of: T1204, ①Tactic: Execution, ①Platforms: Linux, Windows, macOS, Version: 1.2, Created: 11 March 2020, Last Modified: 24 October 2025.

Other sub-techniques of User Execution (5) ▼

An adversary may rely upon a user clicking a malicious link in order to gain execution. Users may be subjected to social engineering to get them to click on a link that will lead to code execution. This user action will typically be observed as follow-on behavior from [Spearphishing Link](#). Clicking on a link may also lead to other execution techniques such as exploitation of a browser or application vulnerability via [Exploitation for Client Execution](#). Links may also lead users to download files that require execution via [Malicious File](#).

ID: T1204.001
Sub-technique of: T1204
①Tactic: Execution
①Platforms: Linux, Windows, macOS
Version: 1.2
Created: 11 March 2020
Last Modified: 24 October 2025

Group – FIN7

FIN7 is a financially motivated threat group that has been active since 2013. FIN7 has targeted the retail, restaurant, hospitality, software, consulting, financial services, medical equipment, cloud services, media, food and beverage, transportation, pharmaceutical, and utilities industries in the United States. FIN7 uses social engineering to manipulate legitimate users and trick users into executing malicious content, allowing the group to abuse trusted user contexts and perform unauthorized actions within targeted systems.

Technique and Tools

MITRE ATT&CK Technique: T1204.001 – User Execution: Malicious File

FIN7 uses this technique to open a malicious file, such as a document or script, that triggers unintended actions on the system by tricking users.

FIN7 uses following tools and methods to implement their technique.

- Built-in Windows command line tool
- Host trojanized digital products
- Performed C2 using DNS via A, OPT, and TXT records to evade detection.
- mimicked WsTaskLoad.exe, which is associated with the Wondershare software suite, by using a malicious executable under the same name.

3. I selected Exploit Public-Facing Application from MITRE ATT&CK using URL <https://attack.mitre.org/techniques/T1190/> which support CWE-863.

The screenshot shows the MITRE ATT&CK website interface. At the top, there's a navigation bar with the MITRE logo and 'ATT&CK'. Below it, a banner mentions 'ATT&CK v18 has been released!'. The main content area is titled 'TECHNIQUES' with a dropdown arrow. A breadcrumb trail reads 'Home > Techniques > Enterprise > Exploit Public-Facing Application'. The title 'Exploit Public-Facing Application' is prominently displayed. The description states: 'Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration. Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets. On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers. Depending on the flaw being exploited, this may also involve Exploitation for Defense Evasion or Exploitation for Client Execution. If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the Cloud Instance Metadata API), exploit container host access via Escape to Host, or take advantage of weak identity and access management policies.'

On the right side, there's a metadata box for ID: T1190. It lists 'Sub-techniques: No sub-techniques', 'Tactic: Initial Access', 'Platforms: Containers, ESXi, IaaS, Linux, Network Devices, Windows, macOS', 'Contributors: Don Le, Stifel Financial; Praetorian; Yossi Weizman, Azure Defender Research Team', 'Version: 2.8', 'Created: 18 April 2018', and 'Last Modified: 24 October 2025'. At the bottom of this box is a 'Version Permalink' link.

Group – APT28

APT28 is a state-sponsored advanced persistent threat (APT) group attributed to Russia's General Staff Main Intelligence Directorate (GRU). This group has been active since at least 2004. The APT28 group is known for abusing authorization weaknesses after gaining initial access, allowing it to perform actions beyond the permissions intended for compromised accounts.

Technique and Tools

MITRE ATT&CK Technique: T1068 – Exploitation for Privilege Escalation

APT28 uses this technique to exploit vulnerabilities in software authorization logic, where access controls exist but are enforced incorrectly. They can use these vulnerabilities to escalate privileges and gain access to sensitive data.

APT28 uses following tools and methods to implement their technique.

- Brute force attacks to obtain valid credentials.
- Deployment malware that has copied itself to the startup directory for persistence.
- Manipulation of access control checks to perform actions intended only for higher-privileged users.
- Abuse of valid but improperly restricted accounts to move laterally and access sensitive systems.

Conclusion

This lab helps to understand how CWE-352 and CWE-863 critical security weaknesses that can be exploited through real-world attack techniques documented in the MITRE ATT&CK framework. CWE-352, Cross-Site Request Forgery allows attackers to abuse trusted user sessions by tricking users into triggering unintended actions without their knowledge. CWE-863, Incorrect Authorization enables attackers to bypass access control mechanisms and perform actions beyond their intended permissions.

Treat groups like FIN7 and APT28 show how they use social engineering, malicious content, and privilege escalation techniques to gain unauthorized access to the system. These vulnerabilities directly impact confidentiality, integrity, and availability of resources in the system. By understanding how CWEs map to attacker behavior, it helps to know improve defensive strategies to implement security controls and prevent cyber-attacks.

References

1. Chapple, M., & Seidl, D. (2023). *CompTIA Security+ study guide with over 500 practice test questions* (9th ed.). Sybex.

2. Caruso, J. (2024). *Inside cyber warfare: Mapping the cyber underworld* (3rd ed.). O'Reilly Media, Inc.
3. MITRE. (2025). *2025 CWE Top 25 Most Dangerous Software Weaknesses*. MITRE CWE. https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html
4. MITRE. (n.d.). *Enterprise techniques*. MITRE ATT&CK. <https://attack.mitre.org/techniques/enterprise/>
5. MITRE. (n.d.). *T1204/00: User Execution: Malicious Link*. MITRE ATT&CK. <https://attack.mitre.org/techniques/T1204/001/>
6. MITRE. (n.d.). *T1190: Exploit Public-Facing Application*. MITRE ATT&CK. <https://attack.mitre.org/techniques/T1190/>